

PRACTICAL AZURE AI SECURITY

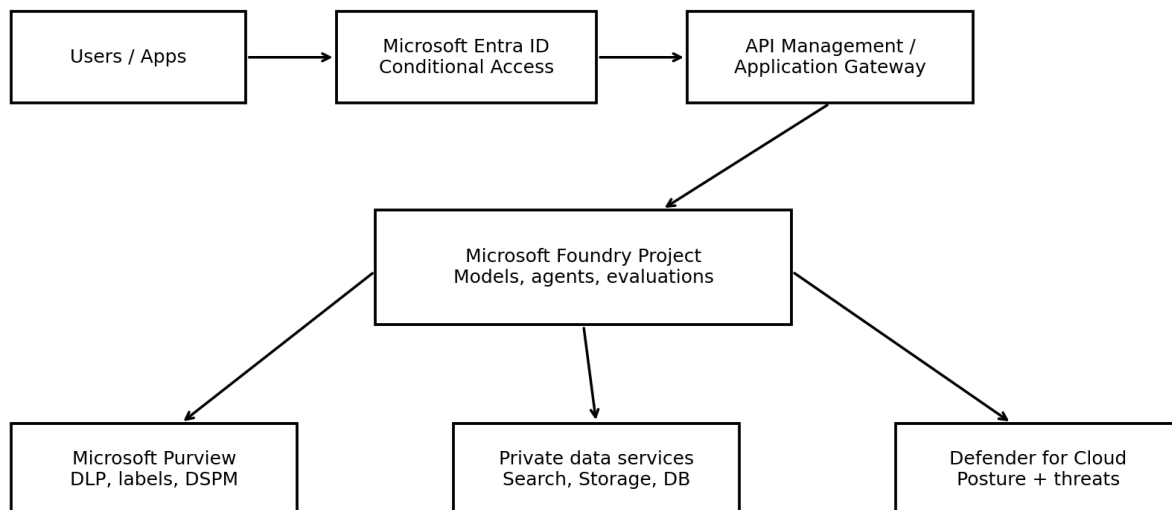
How to Secure Microsoft Foundry, Copilot, Purview, Entra ID, RAG, Agents, and MCP

A practical, beginner-friendly manual for security engineers, architects, GRC professionals, developers, and technology leaders

Alberto (Al) Leiva

Version 1.0 • July 2026

Defense-in-depth reference architecture for Azure AI



Use private connectivity, managed identities, least privilege, data controls, and continuous monitoring.

License: CC BY-NC-SA 4.0

Purpose and responsible-use notice

This manual explains how to design, deploy, govern, and monitor AI workloads in Microsoft Azure using a defense-in-depth approach. It is intended for authorized, ethical, and lawful use. Product names and interfaces change over time, so verify implementation details in current Microsoft documentation before production use.

***Human safety comes first.** No security test, deployment deadline, business objective, or technical experiment is more important than the safety, dignity, privacy, and rights of people affected by an AI system.*

How to use this manual

- Read Chapters 1-4 first if you are new to Azure AI security.
- Use Chapters 5-13 as implementation playbooks.
- Use Chapters 14-16 for testing, operations, incident response, and governance.
- Use the checklists and sample artifacts as portfolio evidence or internal project templates.
- Treat every example as a starting point. Adjust controls to your organization’s data, threat model, legal obligations, and risk tolerance.

Table of contents

Purpose and responsible-use notice	2
How to use this manual	2
Table of contents	2
1. Azure AI security fundamentals	5
Core security objectives	5
Eight practical principles	5
2. Shared responsibility and threat modeling	5
Threat-modeling questions	6
3. Secure reference architecture	7
Recommended trust boundaries	7
4. Identity and access with Microsoft Entra ID	7
Human identities	7
Workload identities	8
RBAC design	8
5. Network isolation and private connectivity	8
Implementation pattern	8
6. Data protection with Microsoft Purview	9
Data protection workflow	9
7. Microsoft Foundry project security	9

Project baseline	9
Connection security	10
8. Securing models, prompts, and content	10
Prompt-injection defenses	10
Output safety	10
9. Secure RAG systems	11
RAG control checklist	11
RAG failure tests.....	11
10. AI agents and non-human identities	12
Agent identity pattern	12
Agent authorization rule.....	12
11. MCP server and tool security	12
Minimum MCP controls	12
MCP threat scenarios	12
12. Copilot security and governance	13
13. Defender for Cloud and continuous posture management.....	13
Operational workflow	13
14. Testing, evaluation, and red teaming	13
Test categories	14
Evaluation evidence	14
15. Logging, monitoring, and incident response	14
What to log.....	14
AI incident playbook	15
16. Governance, compliance, and audit evidence	15
Minimum governance artifacts	15
Sample risk statement.....	15
17. Practical implementation roadmap	15
First 30 days: discover and stabilize.....	15
Days 31-60: harden and test	16
Days 61-90: operationalize.....	16
18. Checklists and sample artifacts	16
Production readiness checklist	16
Sample AI system inventory fields	17
19. Glossary.....	17
20. Official references	18

License and attribution..... 19

1. Azure AI security fundamentals

An Azure AI solution is more than a model endpoint. It normally includes identities, applications, networks, prompts, data sources, search indexes, storage, APIs, agents, tools, monitoring, and human decision points. A secure design protects the entire system rather than focusing only on the model.

Core security objectives

Objective	What it means for AI
Confidentiality	Prevent unauthorized disclosure of prompts, files, embeddings, secrets, model outputs, and sensitive training or grounding data.
Integrity	Prevent unauthorized changes to models, system prompts, retrieval indexes, tools, evaluations, and deployment settings.
Availability	Keep approved AI services reliable while controlling abuse, denial-of-service, and unexpected cost growth.
Privacy	Limit personal-data collection, use, retention, and exposure; support legal rights and organizational policy.
Safety	Reduce harmful, deceptive, discriminatory, or unsafe behavior and provide appropriate human oversight.
Accountability	Record who approved, changed, used, and monitored the system so decisions can be explained and audited.

Eight practical principles

- Know every AI asset and owner.
- Use Microsoft Entra ID and managed identities instead of long-lived secrets whenever supported.
- Grant the smallest required permissions at the narrowest practical scope.
- Use private connectivity and restrict outbound destinations for sensitive workloads.
- Classify and protect data before connecting it to AI.
- Treat prompts, retrieval content, tools, and model output as untrusted input.
- Test safety and security before release and after meaningful changes.
- Monitor continuously and retain evidence.

2. Shared responsibility and threat modeling

Microsoft secures the underlying cloud platform and provides security capabilities. The customer remains responsible for configuration, identities, applications, data, prompts, tool permissions, monitoring, governance, and the decisions made with AI output.

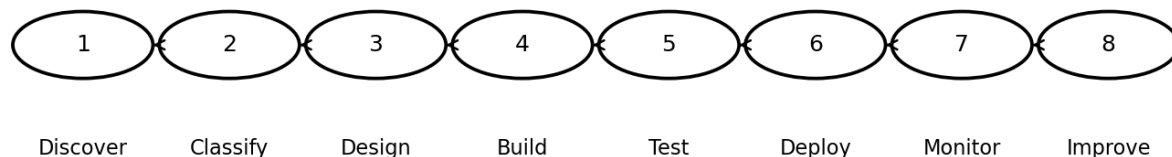
Layer	Typical customer responsibilities
Tenant and subscription	Management groups, policies, budgets, role assignments, logging, resource organization.
Identity	User lifecycle, privileged access, workload identities, Conditional Access, credential

	protection.
Network	Private endpoints, DNS, firewalls, egress control, segmentation, API exposure.
Data	Classification, permissions, retention, encryption choices, DLP, data minimization.
Application	Input validation, authorization, session controls, dependency security, secure coding.
AI behavior	System prompts, grounding, content controls, evaluations, human review, prohibited uses.
Operations	Monitoring, alerting, incident response, change control, audit evidence.

Threat-modeling questions

- Who can submit prompts, upload files, change configurations, deploy models, or invoke tools?
- What sensitive information can enter prompts, indexes, logs, outputs, or evaluation datasets?
- What happens if retrieved content contains hidden instructions or malicious text?
- Can the model call external tools, modify records, send messages, execute code, or approve transactions?
- Which failures could harm people, violate law, expose data, or create material financial impact?
- How are high-impact outputs reviewed, challenged, corrected, and appealed?
- What is the maximum blast radius of one compromised identity, agent, index, or secret?

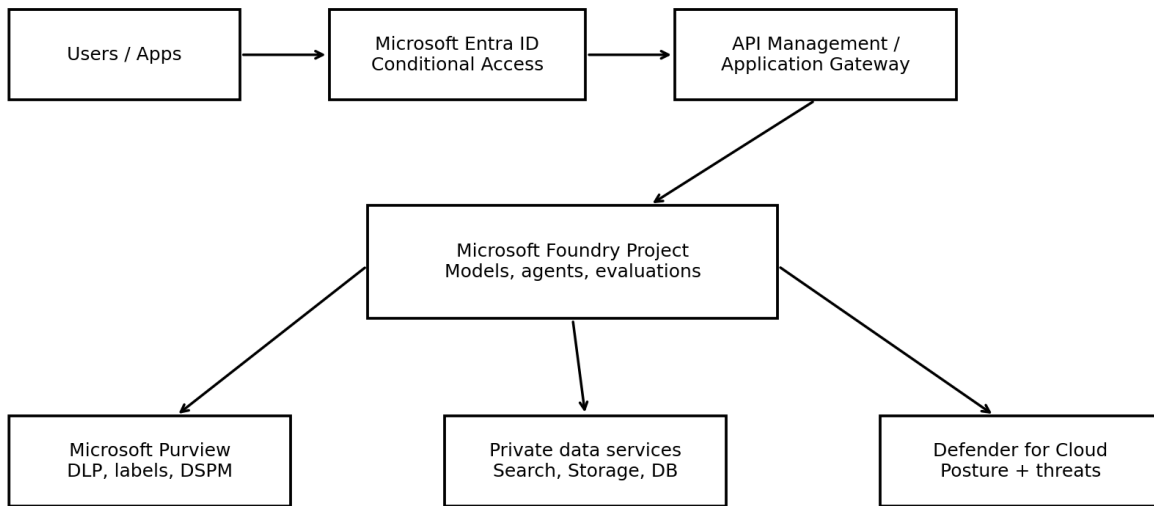
Secure AI lifecycle



Security, privacy, compliance, and human oversight continue through every stage.

3. Secure reference architecture

Defense-in-depth reference architecture for Azure AI



Use private connectivity, managed identities, least privilege, data controls, and continuous monitoring.

A strong baseline uses Microsoft Entra ID for authentication, least-privilege Azure RBAC, managed identities for workload access, private endpoints for sensitive services, controlled outbound connectivity, protected data sources, content and prompt controls, and continuous monitoring through Microsoft Defender for Cloud, Azure Monitor, and Microsoft Purview.

Recommended trust boundaries

- User and endpoint boundary
- Application and API boundary
- Foundry project and model endpoint boundary
- Retrieval and enterprise-data boundary
- Agent tool and external-service boundary
- Administrative and deployment boundary
- Monitoring, audit, and incident-response boundary

4. Identity and access with Microsoft Entra ID

Identity is the primary control plane for Azure AI. Separate human administrators, developers, applications, pipelines, and agents. Do not allow one broad service principal or shared API key to become the identity for an entire environment.

Human identities

- Require multifactor authentication.
- Use Conditional Access based on device, location, risk, and application sensitivity.
- Use Privileged Identity Management for time-limited administrative activation.

- Separate production administration from daily user accounts.
- Review access periodically and remove unused assignments.
- Use access packages or approval workflows for temporary project membership.

Workload identities

Use managed identities for Azure-hosted applications whenever the target service supports Microsoft Entra authentication. Use workload identity federation for supported CI/CD and external workload scenarios to avoid storing client secrets.

Identity type	Best use	Security note
System-assigned managed identity	One Azure resource with the same lifecycle	Automatically removed with the resource; simple ownership.
User-assigned managed identity	Multiple resources or stable identity lifecycle	Review reuse carefully because compromise can affect several workloads.
Workload identity federation	GitHub Actions, Kubernetes, and supported external workloads	Avoids stored secrets by exchanging trusted external identity tokens.
Service principal with certificate	Legacy or unsupported scenarios	Prefer certificates over client secrets; rotate and monitor.
API key	Only when Entra authentication is unavailable or operationally required	Store in Key Vault, restrict use, rotate, and monitor.

RBAC design

- Assign roles at project or resource scope instead of subscription scope whenever possible.
- Separate model deployment, project development, data access, security monitoring, and billing duties.
- Do not grant Owner or Contributor merely to make troubleshooting easier.
- Document every custom role and test that it does not include unintended data-plane permissions.
- Review both management-plane and data-plane access.

5. Network isolation and private connectivity

Network controls reduce exposure but do not replace identity controls. For sensitive workloads, use private endpoints, private DNS, managed virtual networks where available, and explicit outbound controls.

Implementation pattern

1. Disable public network access where business requirements permit.
2. Create private endpoints for Foundry, storage, search, Key Vault, databases, and other dependencies.
3. Configure private DNS zones and validate name resolution from every approved network.
4. Route egress through an approved firewall or controlled outbound mechanism.
5. Allow only required destinations and document why each is needed.
6. Protect administrator access through trusted devices, jump hosts, or secure management paths.
7. Test fail-closed behavior when DNS, firewall, or private-link configuration is incorrect.

Common failure: A project uses a private endpoint for model access but leaves storage, search, or a tool endpoint publicly reachable. Review the full dependency chain.

6. Data protection with Microsoft Purview

Microsoft Purview can help discover sensitive data, apply information protection, enforce data loss prevention, investigate risky activity, and provide visibility into data security posture for AI applications and agents.

Data protection workflow

- Inventory data sources used for prompts, grounding, fine-tuning, evaluation, and logging.
- Classify data and identify legal, contractual, residency, and retention requirements.
- Apply sensitivity labels and access controls.
- Configure DLP policies for approved AI interactions and sensitive-data movement.
- Use DSPM for AI or current Purview posture capabilities to identify risky AI use and unprotected data.
- Review insider-risk and audit signals where legally and organizationally appropriate.
- Test policies with realistic sample data before broad enforcement.
- Record exceptions, owners, expiration dates, and compensating controls.

Data location	Key risks	Minimum controls
Prompts and chat history	Personal data, secrets, confidential business information	Minimize collection, apply DLP, define retention, restrict logging.
Uploaded files	Malware, oversharing, hidden instructions	Scan, classify, authorize, quarantine when needed.
Vector index/embeddings	Sensitive semantic content, cross-user leakage	Use source ACLs, tenant separation, encryption, access trimming.
Evaluation datasets	Production data copied into lower environments	De-identify, restrict, version, and approve.
Model outputs	Sensitive reconstruction, harmful advice, false claims	Grounding, DLP, content controls, human review, provenance.
Logs	Prompts or data stored longer than intended	Redact, limit access, define retention, monitor exports.

7. Microsoft Foundry project security

Treat each Foundry project as a security boundary with a named owner, approved data classification, defined environment, documented purpose, and controlled deployment process.

Project baseline

- Separate development, test, and production resources.
- Use infrastructure as code and peer review for repeatable configuration.
- Use Entra authentication and managed identities where supported.
- Restrict who can create deployments, attach data, modify connections, or publish agents.
- Use customer-managed keys when required by policy and supported by the resource.
- Enable diagnostic settings and export logs to an approved workspace.
- Apply Azure Policy and Defender recommendations.
- Use tags for owner, environment, data classification, business service, and review date.
- Set quotas, rate limits, and budgets to reduce abuse and cost surprises.

Connection security

Connections to search, storage, databases, APIs, and tools are frequent attack paths. Prefer identity-based access. If a secret is unavoidable, store it in Azure Key Vault, restrict retrieval, rotate it, and ensure it never appears in prompts, source code, notebooks, or logs.

8. Securing models, prompts, and content

Prompt-injection defenses

Prompt injection occurs when untrusted input attempts to override system instructions, expose data, or misuse connected tools. No single filter solves the problem. Use layered controls.

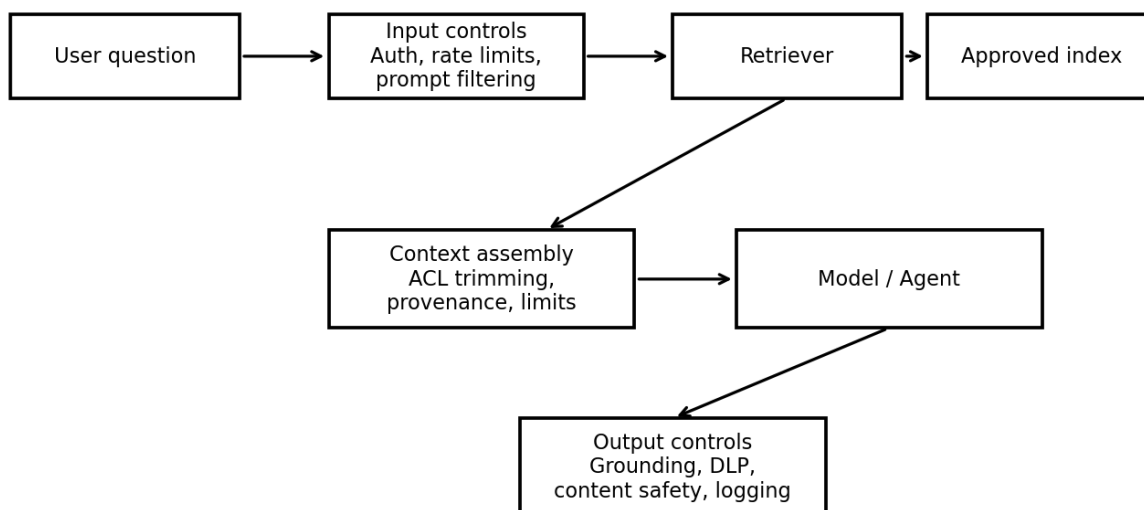
- Clearly separate system instructions, user input, retrieved content, and tool results.
- Treat retrieved documents and web content as untrusted data, not trusted instructions.
- Use least-privilege tools and require explicit authorization checks outside the model.
- Constrain allowed actions with structured schemas and deterministic validation.
- Use Azure AI Content Safety capabilities, including prompt-attack protections where appropriate.
- Do not place secrets or unrestricted credentials in prompts or tool context.
- Require confirmation or human approval for high-impact actions.
- Evaluate known jailbreak, indirect injection, and data-exfiltration scenarios.

Output safety

- Check outputs for harmful content and sensitive data.
- Require citations or source references for knowledge-based responses.
- Display uncertainty and avoid presenting probabilistic output as verified fact.
- Use domain-specific rules for medical, legal, financial, employment, safety, or other high-impact contexts.
- Provide a safe fallback when the system lacks sufficient evidence.
- Log policy decisions without unnecessarily storing sensitive prompt content.

9. Secure RAG systems

Secure retrieval-augmented generation (RAG) flow



RAG does not automatically make a model accurate or secure. It introduces additional data pipelines, indexes, permissions, parsers, and retrieval logic that must be protected.

RAG control checklist

- Authorize access at query time; do not rely only on index-time filtering.
- Preserve source permissions and use security trimming.
- Separate tenants, departments, or classifications when one shared index would create unacceptable leakage risk.
- Validate file types and scan uploaded content.
- Track document provenance, owner, classification, and update date.
- Defend against poisoned documents and indirect prompt injection.
- Limit the number and size of retrieved passages.
- Require the model to distinguish source text from instructions.
- Return citations and allow users to inspect the supporting source.
- Monitor retrieval anomalies, unusual document access, and repeated attempts to enumerate the index.

RAG failure tests

Test	Expected result
User asks for another department's document	No unauthorized content is retrieved or inferred.
Document contains 'ignore all rules' text	The content is treated as data and cannot alter system policy.
A source is deleted or access is revoked	The index is updated promptly and access is removed.
User asks for secrets or personal records	The request is blocked or safely handled according to policy.
Citations do not support the answer	The system states uncertainty or refuses to claim

	verification.
--	---------------

10. AI agents and non-human identities

Agents can plan, retrieve information, call tools, and take actions. Their risk depends less on conversational ability and more on what they can access and change.

Agent identity pattern

- Give every production agent a unique, managed identity where the platform supports it.
- Assign permissions to the agent’s exact purpose, not to all possible future tools.
- Separate read-only and write-capable tools.
- Use approval gates for destructive, financial, legal, personnel, or safety-sensitive actions.
- Record the initiating user, agent identity, tool call, parameters, result, and approval.
- Prevent agents from silently expanding their own permissions.
- Expire unused agents and review ownership regularly.

Agent authorization rule

***The model proposes; trusted application logic authorizes.** Never rely on a model’s statement that an action is permitted. Enforce authorization in code and in the target service.*

11. MCP server and tool security

The Model Context Protocol (MCP) provides a standardized way for AI applications to discover and call tools or access contextual resources. MCP can improve integration, but it can also create a powerful bridge from natural-language input to sensitive systems.

Minimum MCP controls

- Maintain an approved inventory of MCP servers, owners, versions, and data classifications.
- Use authenticated, encrypted transport; do not expose administrative MCP endpoints publicly.
- Use per-server or per-tool authorization rather than one universal credential.
- Validate tool schemas and reject unexpected parameters.
- Allowlist tools and destinations.
- Run servers with minimal operating-system, network, and cloud permissions.
- Separate development and production MCP servers.
- Pin and review dependencies; monitor software-supply-chain risk.
- Log every tool call and correlate it with the user and agent identity.
- Require human approval for high-impact actions.
- Return only the minimum data needed by the model.
- Test for prompt injection that attempts to invoke hidden, unrelated, or unauthorized tools.

MCP threat scenarios

Scenario	Control
Malicious document asks the agent to call an admin tool	Instruction hierarchy, allowlisted tools, external authorization, approval gate.

Compromised MCP server returns poisoned context	Server authentication, integrity monitoring, provenance, output validation.
Tool returns excessive records	Server-side authorization, result limits, field filtering, DLP.
Agent attempts command injection	Structured arguments, strict validation, no direct shell construction.
Stolen MCP credential	Short-lived identity, secretless authentication where supported, monitoring, rapid revocation.

12. Copilot security and governance

Copilot security starts with identity, data permissions, information protection, and governance. A Copilot can surface information that a user is already allowed to access, so excessive permissions and overshared content must be corrected before broad adoption.

- Assess data oversharing and stale permissions.
- Apply sensitivity labels and DLP policies.
- Define approved and prohibited use cases.
- Control plugins, connectors, agents, and external actions.
- Review audit and risk signals.
- Train users not to paste secrets or regulated data into unapproved tools.
- Provide a reporting path for unsafe, incorrect, or sensitive output.
- Measure adoption and risk together rather than measuring usage alone.

13. Defender for Cloud and continuous posture management

Microsoft Defender for Cloud can provide AI workload discovery, security posture recommendations, attack-path context, and runtime threat protection for supported services. Use it as part of a broader operating model, not as a substitute for secure design.

Operational workflow

- Enable the appropriate Defender plans for the subscriptions hosting AI workloads.
- Review the Data and AI security dashboard and AI workload inventory.
- Prioritize internet exposure, excessive privileges, sensitive data, and exploitable attack paths.
- Assign recommendations to accountable owners with target dates.
- Integrate alerts with Microsoft Defender XDR or the organization's SIEM and incident process.
- Validate coverage after new deployments, networking changes, or service migrations.
- Track exceptions and verify that compensating controls remain effective.

14. Testing, evaluation, and red teaming

Security testing should cover the application, identity, data, network, model behavior, retrieval pipeline, agents, tools, and operational controls. Perform testing only with authorization and within defined scope.

Test categories

Category	Examples
Access control	Cross-user leakage, privilege escalation, missing object-level authorization.
Prompt attacks	Direct injection, indirect injection, jailbreaks, instruction leakage.
Data protection	Sensitive prompts, output leakage, index enumeration, log exposure.
RAG integrity	Poisoned documents, stale permissions, unsupported citations.
Agent safety	Unauthorized tools, parameter manipulation, action chaining, excessive autonomy.
Application security	OWASP web/API issues, dependency vulnerabilities, insecure deserialization.
Abuse and availability	Rate-limit bypass, resource exhaustion, cost amplification.
Human factors	Misleading confidence, inadequate warnings, inaccessible controls, unsafe escalation.

Evaluation evidence

- Test case and purpose
- Expected safe behavior
- Actual result
- Severity and affected users
- Model, prompt, index, tool, and application version
- Reviewer and date
- Remediation owner and deadline
- Retest result and approval

15. Logging, monitoring, and incident response

What to log

- Authentication and authorization events
- Administrative changes and deployments
- Model and agent invocation metadata
- Tool calls and action outcomes
- Policy blocks and safety-filter decisions
- Retrieval source identifiers and authorization decisions
- Rate-limit and quota events
- Defender, Purview, Key Vault, network, and application alerts
- Human approvals for high-impact actions

Privacy warning: Do not automatically store full prompts, retrieved passages, and outputs. Define a justified logging purpose, redact sensitive content, restrict access, and set retention.

AI incident playbook

1. Identify and classify the event.
2. Contain access: disable affected agent, endpoint, tool, identity, or connection.
3. Preserve relevant logs and configuration evidence.
4. Assess data exposure, harmful actions, and affected people.
5. Revoke credentials and correct permissions.
6. Remove poisoned content and rebuild indexes when needed.
7. Patch application logic, prompts, or tool controls.
8. Notify legal, privacy, compliance, customers, or regulators according to policy and law.
9. Retest before restoration.
10. Document lessons learned and update controls.

16. Governance, compliance, and audit evidence

A secure AI program needs accountable ownership, approved use cases, risk classification, lifecycle controls, and evidence. Organizations can map controls to frameworks such as NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, the Microsoft cloud security benchmark, and applicable legal requirements.

Minimum governance artifacts

- AI system inventory
- Business owner and technical owner
- Purpose and prohibited uses
- Data-flow and architecture diagram
- Data classification and privacy assessment
- Threat model and risk assessment
- Model and supplier documentation
- Security control plan
- Evaluation and red-team results
- Human-oversight design
- Monitoring and incident-response plan
- Change log and approvals
- Retirement and data-deletion plan

Sample risk statement

Risk: A customer-support RAG assistant may reveal restricted case notes because source permissions are not consistently enforced in the retrieval index. **Impact:** Unauthorized disclosure of personal and confidential information. **Treatment:** Implement query-time security trimming, separate sensitive collections, validate access revocation, add DLP, and test cross-user retrieval before production.

17. Practical implementation roadmap

First 30 days: discover and stabilize

- Inventory Azure AI resources, model endpoints, agents, Copilots, data sources, and owners.
- Identify public exposure, shared keys, excessive privileges, and unmonitored production workloads.

- Enable logging, budgets, and basic Defender/Purview visibility.
- Block clearly prohibited AI uses and remove abandoned resources.
- Create a minimum security standard and exception process.

Days 31-60: harden and test

- Move supported workloads to managed identities and narrow RBAC scope.
- Implement private connectivity for sensitive systems.
- Classify data, apply labels, and configure priority DLP controls.
- Threat-model RAG, agents, and MCP integrations.
- Run security and safety evaluations and remediate high-risk findings.

Days 61-90: operationalize

- Automate policy, infrastructure, and evidence collection.
- Integrate alerts with incident-response workflows.
- Establish periodic access, agent, index, and vendor reviews.
- Create executive metrics for inventory, exposure, remediation, incidents, and exceptions.
- Train developers, security teams, data owners, and end users.

18. Checklists and sample artifacts

Production readiness checklist

- ☐ Named business and technical owners
- ☐ Approved purpose and prohibited uses
- ☐ Data classification completed
- ☐ Threat model reviewed
- ☐ Entra authentication enabled where supported
- ☐ Managed identities used where supported
- ☐ Least-privilege RBAC verified
- ☐ Public network exposure justified or disabled
- ☐ Private endpoints and DNS tested
- ☐ Secrets stored in Key Vault
- ☐ Purview controls and retention defined
- ☐ RAG security trimming tested
- ☐ Agent and MCP tools allowlisted
- ☐ High-impact actions require approval

- ☐ Content and prompt-attack controls tested
- ☐ Defender/monitoring coverage enabled
- ☐ Incident playbook exercised
- ☐ Rollback and shutdown procedures tested
- ☐ Accessibility and human-oversight review completed
- ☐ Final security approval recorded

Sample AI system inventory fields

Field	Example
System name	Customer Support Knowledge Assistant
Owner	Customer Operations
Environment	Production
Azure subscription/resource group	AI-Prod / rg-support-ai
Foundry project	support-assistant-prod
Models	Approved deployment name and version
Data sources	SharePoint export, approved case KB, product catalog
Agents/tools	Search, ticket lookup, draft response
Data classification	Confidential; limited personal data
User population	Authorized support personnel
Risk tier	High
Review date	Quarterly or after material change

19. Glossary

Term	Definition
Agent	An AI-enabled component that can plan, retrieve information, call tools, and take actions.
Azure RBAC	Azure role-based access control for assigning permissions to identities at defined scopes.
Content Safety	Azure AI capabilities for detecting harmful text or images and supporting prompt-attack defenses.
DSPM	Data Security Posture Management; capabilities for discovering and reducing data-security risk.
Embedding	A numeric representation of content used for similarity search and other machine-learning tasks.
Foundry	Microsoft's Azure platform for building, evaluating, deploying, and operating AI applications and agents.
Grounding	Providing a model with approved context or sources to improve relevance and reduce unsupported answers.
Managed identity	A Microsoft Entra workload identity managed by Azure for supported resources.
MCP	Model Context Protocol, a standard for connecting AI applications with tools and contextual resources.

Prompt injection	Untrusted input that attempts to override instructions, expose data, or misuse tools.
RAG	Retrieval-augmented generation, where relevant content is retrieved and supplied to a model.
Security trimming	Filtering retrieved content according to the current user's authorization.
Workload identity	A non-human identity used by an application, service, agent, or automation.

20. Official references

[Azure AI security best practices](#)

[Azure security baseline for Microsoft Foundry](#)

[Microsoft Foundry network isolation](#)

[Authentication and authorization in Microsoft Foundry](#)

[Role-based access control for Microsoft Foundry](#)

[Managed identities for Azure resources](#)

[Microsoft Entra Workload ID](#)

[Microsoft Purview protections for AI](#)

[Data Security Posture Management for AI](#)

[Microsoft Purview support for AI agents](#)

[Defender for Cloud AI security posture management](#)

[Defender for Cloud AI threat protection](#)

[Azure AI Content Safety](#)

[Microsoft Foundry Agent Service](#)

[Agent identity concepts in Microsoft Foundry](#)

[Baseline Microsoft Foundry chat reference architecture](#)

Maintenance note: Microsoft services and product names evolve. Review the official references before implementing controls or publishing future editions.

License and attribution

Copyright © 2026 Alberto (Al) Leiva. This manual is licensed under Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0).